Deploying and Configuring AAA

IE3122: Network Security | Week 10

Where the decision gets made, who makes it, and how to actually configure it

Today's Agenda

- Local versus server-based (centralised) AAA
- Device administration AAA versus network access AAA, and why that distinction matters
- RADIUS versus TACACS+, in full technical detail
- AAA method lists, ordered fallback between AAA sources
- Configuring AAA on Cisco devices: concept alongside the actual command templates

Learning Outcomes for Today

LO3

– Analyse security requirements and recommend appropriate technologies.

LO4

– Evaluate different security technologies, compare them, and identify appropriate use cases.

LO5

– Configure security technologies to satisfy specific requirements.

Local vs. Server-Based AAA

Where the decision actually gets made

Local AAA

- Mechanism: each device, a router or switch, keeps its own username and password database and makes its own authentication decisions entirely independently.
- Example use case: a small office with two or three routers managed directly by one administrator, or a fallback method configured on every device in case a central server later becomes unreachable.
- Strengths: no external server or network dependency, so it works even if the rest of the network is completely down; simple to set up with no extra infrastructure; takes effect immediately, with nothing else that needs to be reachable first.
- Weaknesses: doesn't scale. With many devices, adding, removing, or updating a single user means logging into and changing every device individually, and each device's own logs stay separate rather than forming one consistent audit trail.

Server-Based (Centralised) AAA

- Mechanism: devices forward authentication and authorization requests to a dedicated AAA server, running RADIUS or TACACS+, which makes the decision and reports back.
- Example use case: a large enterprise with hundreds of routers, switches, and VPN concentrators all authenticating against one central TACACS+ server, or a university campus where every WiFi access point authenticates students and staff against one RADIUS server tied to the institution's directory.
- Strengths: one consistent user database and one place to manage accounts; one centralised audit log across the entire network; scales cleanly to large networks without per-device administrative overhead.
- Weaknesses: introduces a genuine new dependency, since an unreachable AAA server means devices can't authenticate anyone against it unless a fallback is configured; adds infrastructure cost and complexity; and becomes a single, high-value target, since compromising the AAA server could compromise authentication for the whole network.

Local vs. Server-Based: Comparison

Aspect	Local AAA	Server-Based AAA
Consistency	Managed per device, inconsistent at scale	One central database, consistent everywhere
Scalability	Poor, doesn't scale beyond a few devices	Strong, scales to large networks
Dependency	None, entirely self-contained	Depends on the AAA server being reachable
Typical use	Small networks, or as a fallback method	Enterprise networks

Device Administration AAA vs. Network Access AAA

What is actually being protected

Device Administration AAA

- Controls who can log into the network's own infrastructure devices, a router or switch's CLI, and once in, exactly which commands they're allowed to run.
- The stakes here are can this person reconfigure the network, and the natural granularity is per command.
- This is TACACS+'s traditional home ground, covered in detail shortly.

Network Access AAA

- Controls who or what can get onto the network in the first place: WiFi association, a VPN connection (recall Week 9), or wired 802.1X port authentication.
- The stakes here are can this device or user reach the network at all. There's no equivalent of per-command granularity, since an end user connecting to WiFi isn't issuing router commands.
- This is RADIUS's traditional home ground, built for fast, high-volume, simultaneous connection handling rather than fine-grained command control.

Why This Distinction Actually Matters

- TACACS+'s full-packet encryption and its clean separation of all three AAA functions matches device administration's need for fine-grained, secure command control.
- RADIUS's lighter design, encrypting only the password, and bundling authentication with authorization matches network access's need for fast, high-volume connection handling.
- Neither protocol is simply better overall. Each is well suited to the specific stakes and scale of its own traditional use case, which is exactly why both still exist side by side today.

RADIUS vs. TACACS+

Two protocols, two different jobs

RADIUS: Mechanism and Use Cases

- Remote Authentication Dial-In User Service. Despite the dated name, it's the dominant protocol for modern network access AAA.
- Transport: UDP, on ports 1812 for authentication and authorization and 1813 for accounting.
- Encrypts only the password field in the packet. The rest, including the username, travels unencrypted, and it bundles authentication and authorization into a single response rather than treating them as separate exchanges.
- Use cases: WiFi authentication via 802.1X, VPN remote access (recall Week 9), and its original historical role authenticating ISP dial-up and broadband customers, anywhere many simultaneous connections need fast, lightweight handling.

RADIUS: Strengths and Weaknesses

- Strengths: an open, multi-vendor standard (RFC 2865 and 2866) supported broadly across many manufacturers' equipment, not locked to one vendor. Lightweight and fast, since UDP and its combined authentication-authorization response suit high-volume, simultaneous connection handling well. Straightforward to deploy across a mixed-vendor environment.
- Weaknesses: only the password is encrypted, so usernames and other attributes cross the network in plain text, a genuine security gap compared to TACACS+. UDP itself gives no guaranteed delivery, unlike TCP. Bundling authentication and authorization together also means less flexibility to control each independently.

TACACS+: Mechanism and Use Cases

- Terminal Access Controller Access-Control System Plus. Cisco's own protocol for device administration AAA.
- Transport: TCP, on port 49, giving reliable delivery that UDP doesn't guarantee.
- Encrypts the entire packet body, not just the password, and cleanly separates all three AAA functions into genuinely independent exchanges rather than bundling them.
- Use cases: administering Cisco routers and switches, controlling exactly which CLI commands a given administrator can run, and any enterprise environment needing a detailed, per-command audit trail for its own infrastructure.

TACACS+: Strengths and Weaknesses

- Strengths: full-packet encryption gives meaningfully stronger confidentiality than RADIUS. Genuinely separating authentication, authorization, and accounting allows fine-grained control over each independently, including command-level authorization. TCP provides reliable delivery.
- Weaknesses: Cisco-proprietary, so it isn't natively supported across other vendors' equipment the way RADIUS is. Carries heavier protocol overhead than RADIUS, since it encrypts the full packet and rides on TCP, making it less suited to very high-volume simultaneous-connection scenarios such as thousands of WiFi clients.

COMPARISON

RADIUS vs. TACACS+: Full Comparison

Aspect	RADIUS	TACACS+
Transport	UDP	TCP
Reliability	No built-in retransmission	Reliable delivery via TCP
Encryption	Password only	Entire packet
AAA separation	Authentication and authorization combined	All three functions fully separate
Vendor support	Open, multi-vendor (RFC 2865/2866)	Cisco-proprietary
Overhead	Lower, suited to high connection volume	Higher, justified by finer administrative control
Typical use	Network access (WiFi, VPN)	Device administration (router/switch CLI)

AAA Method Lists

What happens when the first choice isn't available

What a Method List Actually Is

- A method list defines an ordered sequence of AAA methods to try, one after another, until one of them succeeds or the whole list is exhausted.
- A typical example: try TACACS+ first, and if the TACACS+ server doesn't respond at all, fall back to the local username and password database.
- This directly solves server-based AAA's single point of failure from earlier. If the central server becomes unreachable, the device doesn't simply lock everyone out, it falls back to a still-functioning local option instead.

The Same Logic as an ACL, Applied to AAA

- Recall Week 7: an ACL is processed top to bottom, and the first matching statement wins, with everything below it never even evaluated for that packet.
- A method list works the same way. Each method is tried in the order it's listed, and the first one that actually produces a usable result, success or a definitive deny, is what gets applied.
- Fall-through to the next method only happens when a method is unavailable, such as the server not responding at all, not simply because it denied the request.

Configuring AAA on Cisco Devices

Concept alongside the actual command templates

Step 1, Enable AAA

- Before any AAA command works at all, AAA itself must be explicitly enabled on the device.

```
aaa new-model
```

Step 2, Local AAA

- Create a local user, then tell the device to authenticate logins against that local database.

```
username admin privilege 15 secret StrongPass123
aaa authentication login default local
```

Step 3, TACACS+ Server-Based AAA

– Define the TACACS+ server and its shared key, then build a method list that tries TACACS+ first and falls back to local if the server is unreachable.

```
tacacs server TACACS-SERVER1
 address ipv4 192.168.1.100
 key MySharedKey
aaa authentication login default group tacacs+ local
aaa authorization exec default group tacacs+ local
aaa accounting exec default start-stop group tacacs+
```

Step 4, RADIUS Server-Based AAA

– Define the RADIUS server and its shared key, then build a method list the same way, RADIUS first, local as the fallback.

```
radius server RADIUS-SERVER1
 address ipv4 192.168.1.200 auth-port 1812 acct-port 1813
 key MySharedKey
aaa authentication login default group radius local
```

– *Notice the method list itself: group tacacs+ local, or group radius local. The order you write the command in is the fallback order, matching exactly the ACL-style top-to-bottom logic from the previous section.*

Summary

- Local AAA needs no infrastructure but doesn't scale. Server-based AAA scales and centralises, but adds a dependency on the server being reachable.
- Device administration AAA and network access AAA protect genuinely different things, which is exactly why TACACS+ and RADIUS each dominate a different one of them.
- TACACS+ trades a proprietary standard for full-packet encryption and clean AAA separation. RADIUS trades weaker encryption for open, multi-vendor, high-volume connection handling.
- A method list is how a device survives its primary AAA source going down, falling back in a defined order rather than simply locking everyone out.

This Week's Lab & Tutorial

- Lab: to be planned in a follow-up discussion, once we've confirmed which of today's configurations are genuinely supported and testable in Packet Tracer.
- Tutorial worksheet: study-notes-style questions covering local versus centralised AAA, RADIUS versus TACACS+, method lists, and Cisco configuration. Use it to prep for the mid-semester test.

References

- Santos & Stuppi, CCNA Security 210-260 Official Cert Guide, 1st Ed., Cisco Press.
- Kaufman, Perlman, Speciner & Perlner, Network Security: Private Communication in a Public World, 3rd Ed., Prentice Hall.
- Cisco Networking Academy, CCNA Security curriculum (AAA configuration chapters).